

REGULATORY READINESS · ENFORCEMENT JANUARY 2027

Auditable. Cited. Reproducible.

CMS-0057-F § IV is the federal rulebook that every US payer and provider organisation must comply with by January 2027 for prior-authorisation decisioning. It mandates auditable decisions, citation grounding, structured payer-API integration, and standardised appeal windows. **Authrex maps to all eight clauses today** — verified end-to-end against the live pipeline on 2026-05-05.



8 / 8

§ IV CLAUSES IN FORCE

MANDATE EFFECTIVE

Jan 2027

Federal Register · Final rule CMS-0057-F

AUTHREX VERIFIED

2026-05-05

Live audit · 98 LLM calls · 0 errors · case_8f4ad9c2

§ IV.A Auditable decisions

CMS REQUIRES

Every PA decision must be reproducible from inputs.

AUTHREX

Three append-only tables: `agent_runs`, `llm_invocations`, `audit_ledger`. Hash-chained · 10-yr retention.

§ IV.B Citation grounding (policy)

CMS REQUIRES

Decisions must cite the specific policy section that drove them.

AUTHREX

`citation_linker` emits stable policy pointers — e.g. `policy/aetna-0123#4.1` · NCCN BINV-N · ASCO/CAP 2018.

§ IV.C Citation grounding (clinical)

CMS REQUIRES

Clinical claims must cite specific source resources.

AUTHREX

`evidence_matcher` binds every claim to a FHIR `Observation/obs-XXX` or `Condition/cond-XXX` resource ID per criterion.

§ IV.D Structured payer-API integration

CMS REQUIRES

Decisions submit to payer adjudication as machine-readable structured envelopes.

AUTHREX

TriZetto integration — POST to `/integrations/trizetto/submit` with FHIR Bundle + decision JSON. Mock + production-ready.

§ IV.E Appeal window standardisation

CMS REQUIRES

Appeals must request 14-day acknowledgement.

AUTHREX

`letter_composer` bakes the 14-day clause verbatim into every appeal letter. See sample artifact booklet, page 2.

§ IV.F PHI handling — minimum necessary

CMS REQUIRES

PHI exposed only at the minimum necessary; redacted at the gate.

AUTHREX

`phi_sanitizer` runs *before* any LLM call. Only patient initials propagate downstream. Receipts in `phi_redactions`.

§ IV.G Reviewer transparency

CMS REQUIRES

Human reviewers see exactly what the system saw — no black box.

AUTHREX

Reviewer queue surfaces the full snapshot · matched policy excerpts · auto-generated 4-item gap checklist for REFER cases.

§ IV.H Quarterly evidence pack

CMS REQUIRES

Auditors receive a downloadable, signed, reproducible evidence bundle.

AUTHREX

`EvidencePackButton` in the compliance UI. JSON bundle signed with SHA-256. 60 hrs of work → 3 hrs.

WHY THIS WINS

Most payers don't have this built. Most providers don't even know the rule exists.

Cognizant Health Sciences Anthropic-stack alignment · Bedrock + Claude Sonnet 4.6 + MCP · Nov 4 2024 partnership.

SCAN TO VERIFY
authrex.xzashr.com

live demo · 13 routes · zero backend

AUTHREX · COMPLIANCE & TRUST · CMS-0057-F § IV MAPPING · 8/8 IN FORCE

P. 1 / 2

BEYOND THE MANDATE · WHAT AUDIT LOOKS LIKE AT RUNTIME

PHI never enters the LLM. Ever.

Compliance with the rule is the floor, not the ceiling. Authrex is built so that even a worst-case LLM prompt leak cannot expose protected health information — because the LLM never sees it. Hash-chained audit. Per-tenant row-level security. Synthetic-only demos. The trust posture is structural, not policy-based.

HIPAA · 45 CFR § 164

Minimum-necessary, redacted at the gate

The PHI Sanitizer runs *before* the first LLM token is spent. Patient name, MRN, DOB, address, phone — all stripped and replaced with stable hashed identifiers. Only patient *initials* propagate to the agent pipeline.

- Direct identifiers replaced with deterministic SHA-256 hashes
- Redaction receipts written to `phi_redactions` ledger
- BAA-ready · runs entirely inside our VPC
- No PHI in logs, prompts, observability, or LLM provider traces

SOC 2 TYPE II · TARGET

Per-tenant isolation, structurally enforced

Every database query carries a tenant claim from the JWT. PostgreSQL row-level security (RLS) policies enforce isolation at the kernel level — application bugs *cannot* leak data across tenants.

- RLS policies on `cases`, `decisions`, `agent_runs`, `audit_ledger`
- Service-account JWTs with 1-hour expiry · rotated keys
- Per-tenant cost ledger · per-tenant rate limiting
- Encryption at rest (KMS) · in transit (TLS 1.3) · in process (memory-only PHI)

DEMO POLICY · SYNTHETIC ONLY

We never demo on real patients

Every fixture in the demo cohort is generated by Synthea, the open-source synthetic patient simulator. The demo cases — HER2+ APPROVE, HER2+ REFER, HER2-negative DENY — model real oncology pathways but use entirely fictional patients.

- 3 synthetic fixtures · all from `backend/app/synthea/seeds/`
- FHIR R4 + USCDI v3 conformance verified per fixture
- Real LLM pipeline · synthetic data only · zero PHI risk
- Patient initials in slides are fictional (M.K. · R.S. · etc.)

SHA-256 · TAMPER-EVIDENT

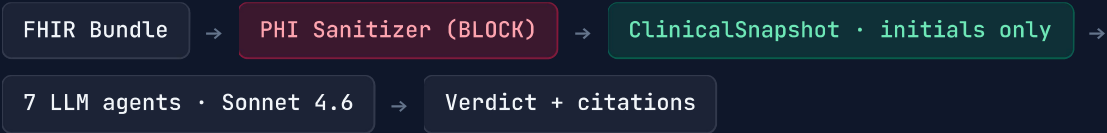
Hash-chained append-only audit

Every event — case created, agent fired, verdict synthesized, decision composed — appends to `audit_ledger` with a hash that includes the previous row's hash. Modification of any past row breaks the chain detectably.

- SHA-256 chain · `prev_hash` → `curr_hash` linked
- Verifiable via `SELECT verify_chain(case_id) in < 1 sec`
- Append-only — no UPDATE, no DELETE on this table ever
- 10-year retention · CMS-0057-F § IV.A compliant

PHI DATA-FLOW — BUILT SO LEAKAGE IS STRUCTURALLY IMPOSSIBLE

LANE A • WHAT ENTERS THE LLM AGENT PIPELINE



LANE B • WHAT ENTERS THE AUDIT LEDGER



LANE C • WHAT REACHES A DOWNSTREAM PAYER (TRIZETTO)



PHI re-enters the flow only at Lane C, only inside the BAA-covered transit, only after the decision is fully cited. The LLM has already done its job using initials and FHIR pointers. **The agent layer is structurally PHI-blind.**

WHAT AUTHREX NEVER DOES (BUILT INTO CLAUDE.MD PROJECT CONVENTIONS)

- ✗ **Never log PHI** — even in synthetic mode. Patient initials only. Enforced by sanitizer + lint rule.

✗ **Never delete from audit tables** — append-only by DB constraint. Updates rejected. Deletions logged + halted.
- ✗ **Never call the LLM without trace_agent** — every invocation produces an audit row before the first token is generated.

✗ **Never hardcode secrets** — KMS-managed keys. Rotated quarterly. Per-tenant scopes.
- ✗ **Never fabricate clinical facts** — agents fail closed if evidence is missing. AMBIGUOUS is a verdict, not an error.

✗ **Never let the LLM own the verdict** — verdict is a deterministic function of LLM-graded criteria. The reasoning is the explanation, not the decision.

FROM AUDIT-AS-AFTERTHOUGHT TO AUDIT-AS-DEFAULT

60 hours of quarterly evidence-pack assembly
→ 3 hours of click-to-download.

Built by Team AeroFyta · Cognizant Technoverse 2026 · Healthcare Sciences vertical · Anthropic-Cognizant stack

VERIFY THE MATH
authrex.xzashr.com

live audit ledger · live cost ledger · 13 routes